המסלול האקדמי המכללה למינהל
מדעי המחשב

ת.ז הסטודנט:_____
מס' חדר:_____ מס' נבחן:_____

בחינה בקורס: מבוא לאבטחת סייבר
קוד קורס: 689156
תאריך הבחינה: 04/12/2022 שעת הבחינה: 14:00
שנה"ל: תשפ"ב סמסטר: קיץ מועד: מיוחד
מרצה: ד"ר מנחם ליבוביץ
משך הבחינה: 03:00 שעות

הוראות לנבחן:

- **בבחינה 2 חלקים:**

חלק א' – שאלה פתוחה (סה"כ בחלק זה 28 נקודות)

א. יש להשיב **במקום המיועד בטופס הבחינה בלבד**

חלק ב' – 12 שאלות ברירה (סה"כ בחלק זה 72 נקודות)

א. יש להשיב על כל השאלות

ב. משקל כל שאלה 6 נקודות

ג. יש לבחור את התשובה הנכונה ביותר ולסמנה בדף הקידוד **בעט שחור/כחול בלבד באופן ברור ומודגש**

ד. **רק דף הקידוד ייבדק**

ה. ***** חשוב מאוד:**
בדף הקידוד יש לרשום ולקדד את מספר המבחן המופיע בראש הדף בצד ימין (מספר בן 3 ספרות)
יש לרשום את מספר תעודת הזהות במקום המיועד בכתב יד ברור (כולל ספרת הביקורת)

- הבחינה ללא חומר עזר
- שימוש במחשבון כיס: כן
- מחברת טיוטה: לא
- אין לסמן על דף הקידוד ו/או שאלון הבחינה במַדְגֵּשׁ (מַרְקֶר) זוהר
- יש להחזיר את טופס השאלון

בהצלחה!!!

לא לשימוש

חלק א': שאלה פתוחה - 28 נקודות

בחלק זה שאלה אחת. יש להשיב **במקום המיועד בטופס הבחינה בלבד**.

א. ביטקוין דואג לעדכן את רמת הקושי במערכת כך שישמר ממוצע של 10 דק' כזמן ממוצע שבו לוקח למצוא בלוק חדש לשרשרת. ברגע שבלוק חדש נמצא, הminer שמצא אותו מפרסם את הבלוק החדש לשאר הרשת. בהתאם לגודל הרשת הנוכחי, נגדיר שמהרגע שה miner מצא את הבלוק ועד שאחרון המשתתפים בתחזוקת הרשת שמע עליו עוברת כדקה. מציעים שינוי לרשת הביטקוין, כך שבעקבות השינוי, רמת הקושי תתעדכן כך שישמר ממוצע של 10 שניות כזמן ממוצע שבו לוקח למצוא בלוק חדש לשרשרת. נתון שהשינוי יעודכן אצל כל המחשבים באופן מיידי.

האם שינוי זה טוב או לא טוב מבחינת האופן שבו הרשת עובדת? נמקו היטב.

<u>תשובה:</u>

לא לשימוש

ב. שרת DNS מקומי, כלומר local resolver, פועל באופן הבא. בתחילת הריצה השרת בוחר באקראי פורט ממנו הוא שולח את כל הבקשות. לכל בקשה השרת מצרף מספר אקראי באורך 16 סיביות. כתוצאה מהאופן הנ״ל שבו השרת פועל, השרת חשוף להתקפות הרעלה.

מוצע להתגונן כנגד המתקפה על ידי כך שאם השרת מקבל 3 תשובות לשאילתא שבהן מספר מזהה שגוי, אז הוא מתעלם מכל שאר התשובות לשאילתא, ושולח את השאילתא שוב, עם מספר מזהה אחר.

האם הצעה זו תקשה על הרעלת DNS (ואם כן, בכמה?)

האם ההצעה עלולה לחשוף את השרת להתקפות נוספות?

נמקו.

<u>תשובה:</u>

לא לשימוש

ג. נתון עץ מרקל עם 8 עלים, אשר ה hashים שלהם הם: הערך הראשון (כלומר: 11111111) הוא העלה השמאלי ביותר, הערך השני הוא העלה השני הכי שמאלי וכך הלאה)

11111111

22222222

33333333

44444444

55555555

66666666

77777777

88888888

כמו כן, נתון שפונק' ה hash אשר בשימוש בצמתים של העץ מוציאה כפלט את הספרה הראשונה, השלישית, חמישית ושביעית של הקלט הראשון ואז את הספרה הראשונה, השלישית, חמישית ושביעית של הקלט השני. למשל, אם הקלט הוא:

abcdefgh, 01234567

אזי הפלט הוא:

aceg0246

מה ערכו של שורש העץ?

הציגו את העץ המלא.

<u>תשובה:</u>

לא לשימוש

ד. נתון ciphertext באורך 5 תוים. ה ciphertext נוצר על ידי צופן החלפה (צופן החלפה ממש ולא "סתם" צופן הזזה), ונתון שהא"ב של השפה מורכב מ 40 תוים.

כמה plaintexts ישנם שיכולים להתאים ל ciphertext הנ"ל, אם כל חמשת התווים בciphertext הינם זהים? נמקו

<u>תשובה:</u>

כמה plaintexts ישנם שיכולים להתאים ל ciphertext הנ"ל, אם כל חמשת התווים בciphertext הינם שונים? נמקו

<u>תשובה:</u>

לא לשימוש

חלק ב': שאלות ברירה - 72 נקודות

בחלק זה 12 שאלות. משקל כל שאלה 6 נקודות. יש להשיב על כל השאלות. יש לסמן את התשובה הנכונה ביותר, בעט שחור או כחול בלבד באופן ברור ועל פי ההנחיות, **בדף הקידוד המצורף בלבד**.

<u>שאלה מספר 1:</u>

אליס ובוב רוצים לדבר ביניהם בצורה מוצפנת ומאובטחת כך שחווה לא תוכל לדעת מה תוכן ההודעות שהם שולחים אחד לשניה. הדרך היחידה של אליס ובוב לתקשר הוא דרך ערוץ התקשורת שביניהם.

נתון שלחווה יש יכולות האזנה, כלומר היא יכולה לראות הודעה הנשלחת בין אליס לבוב אך אין לה יכולות אחרות, בפרט, לחווה אין יכולות MitM והיא אינה יכולה לשלוח הודעות לאליס/בוב כלל - גם לא לשלוח הודעות משוכפלות מאליס/בוב.

מוצעות להלן מספר הצעות לקיום התקשורת בין אליס לבוב כך שהתקשורת תהיה מאובטחת.

איזו שיטה <u>לא</u> תעבוד?

א. אליס ובוב יתקשרו באמצעות הצפנה א-סימטרית. כל אחד מהם שולח לשני דרך הערוץ את המפתח הפומבי שלו ומאותו הרגע אליס שולחת לבוב את ההודעות שלה מוצפנות בעזרת המפתח הפומבי שלה (בוב אותו דבר, שולח הודעות שמוצפנות בעזרת המפתח הפומבי שלו).

ב. אליס ובוב יתקשרו באמצעות הצפנה סימטרית. הם מקיימים ביניהם החלפת מפתחות מבוססת דיפי-הלמן ומאותו הרגע כל ההודעות מוצפנות בהתאם.

ג. אליס ובוב יתקשרו באמצעות הצפנה סימטרית. הם ישלחו כל אחד לשני את התעודה שCA שכולם סומכים עליו הנפיק לכל אחד מהם, ואז יריצו את אלגוריתם דיפי-הלמן (וישתמשו בתעודות לאבטחת התהליך) ומאותו הרגע כל ההודעות מוצפנות בהתאם.

ד. אליס ובוב יתקשרו לסירוגין באמצעות הצפנה סימטרית והצפנה א-סימטרית. כאשר הם מתקשרים בהצפנה סימטרית הם מקיימים ביניהם החלפת מפתחות מבוססת דיפי-הלמן ומאותו הרגע כל ההודעות מוצפנות בהתאם. כאשר הם מתקשרים באמצעות הצפנה א-סימטרית הם ישלחו כל אחד לשני את התעודה שCA שכולם סומכים עליו הנפיק להם ומאותו הרגע כל ההודעות מוצפנות בהתאם (כמו שמצפינים ומפענחים בהצפנת מפתח פומבי רגילה).

<u>שאלה מספר 2:</u>

איזו מבין הטענות הבאות <u>אינה</u> נכונה?

א. אליס בנתה אתר בית שרץ על foo.com בכתובת: http://foo.com/~alice ונתנה גישה לאתר הבית שלה לכל חבריה. לבוב, שאינו חבר של אליס, יש אתר בית משלו על foo.com בכתובת: http://foo.com/~bob. בוב החליט שכאשר ויקי, אחת מחברותיה של אליס, תגלוש לאתר הבית שלו, הוא ישים באתר הבית שלו iframe עם כתובת האתר של אליס ויקרא ממנו את התוכן של אתר הבית של אליס באמצעות javascript. כאשר בוב ינסה זאת, הוא יגלה, לצערו, שמנגנון ה same origin policy ימנע מהסקריפט שלו גישה למידע החוזר מאתר הבית של אליס.

ב. ניצול חולשת SQL injection כדי לבצע התקפת XSS הינו תרחיש הגיוני.

ג. אתר מסויים השתמש בחיטוי קלט כדי למנוע התקפות SQL injections. האתר הסיר את התווים: '=- (כל אחד בנפרד) מהקלטים של המשתמשים. למרבה הצער, הם שכחו את התו ; וזה מה שגרם להתקפת sql injection כנגד האתר. זאת דוגמא קלאסית לחסרון של שיטת blacklisting.

ד. בהתקפות stored XSS ו reflected XSS, הקוד הזדוני מוחזר כחלק מהתשובה של השרת

<u>שאלה מספר 3:</u>

איזו מבין הטענות הבאות נכונה?

א. miner שמתחזק את כל הבלוקצ'יין באופן שוטף, יכול לעקוב אחר טרנזקציות ולדעת כמה ביטקוין יש לכתובת ביטקוין מסויימת ברגע נתון

ב. כדי לבזבז ביטקוין אין צורך במפתח הפרטי של הארנק הרלוונטי

ג. ביצוע שינויים במטבע הביטקוין מחייב אישור של סטושי

ד. ב micro payments, אליס חייבת לסמוך על בוב (ספק השירות) שישחרר לה את הכסף המגיע לה

<u>שאלה מספר 4:</u>

איזו מבין הטענות הבאות נכונה?

א. הכח של ההמונים, למשל באמצעות botnet, הוא הכח המניע מאחורי התקפת DDoS

ב. התקפת קמינסקי היא בראש ובראשונה התקפת DoS

ג. התקפות DoS נעשות אך ורק בשכבה הפיזית, הלינק, התעבורה, והרשת

ד. ראשי התיבות DoS הן של התקפות Disk on Stack

<u>שאלה מספר 5:</u>

היכן ביטקוין משתמש ב nonce?

א. בתהליך החיפוש אחר בלוק חדש (הבלוק הבא שיצטרף לבלוקצ'יין)

ב. כאשר miner מצטרף אל הרשת

ג. ב hard fork

ד. ב soft fork

<u>שאלה מספר 6:</u>

איזו מבין הטענות הבאות <u>אינה</u> נכונה?

א. הגדרה נכונה של IDS מונעת התקפות DNS poisoning

ב. תוקף בעל יכולות eavesdropping בין קורבן לשרת ה DNS שאליו פנה לא תמיד יצליח בהתקפת DNS poisoning

ג. תוקף בעל יכולות MitM בין קורבן לשרת ה DNS שאליו פנה אינו צריך לנחש את ה transaction Id כדי להצליח בהתקפת DNS poisoning

ד. פרדוקס יום ההולדת אינו עקרון ייעודי עבור התקפת הרעלת ה DNS של קמינסקי, והוא עקרון שעומד בפני עצמו ושימושי גם לדברים אחרים.

<u>שאלה מספר 7:</u>

איזו מבין הטענות הבאות <u>אינה</u> נכונה?

א. מניעת התקפות הרעלת ARP משמעותה הפסקה גורפת בשימוש בכתובות MAC

ב. תוקף MitM עלול לנסות לבצע התקפת degradation כנגד הקמת חיבור SSL/TLS

ג. התקפת degradation כנגד switch מבוצעת ע"י תוקפים הרוצים לקבל יכולות האזנה ברשת

ד. התקפת ARP poisoning עובדת כי בפרוטוקול ARP אין שימוש באימות ההודעות

<u>שאלה מספר 8:</u>

איזו מבין הטענות הבאות נכונה?

א. ב syn-flood תוקף יעדיף כתובת IP מזוייפות כ source ובעיקר כאלו שלא יענו, כדי, בין השאר, למנוע החזרת RST על ה syn+ack ולמנוע חסימה של ההתקפה ע"י חסימת כתובות ספציפיות

ב. לא ניתן למנוע התקפות שנמוך כנגד switch

ג. על מנת לבצע ARP poisoning, התוקף זקוק ליכולת MITM

ד. שימוש ב syn-cookies מכריח את השרת לשמור אצלו בזיכרון את כל ה TCB החל מקבלת ה syn הראשוני

שאלה מספר 9:

בפרוטוקול TLS, ה pre master secret מוצפן באמצעות?

א. המפתח הציבורי של השרת

ב. המפתח הסימטרי של ה CA

ג. המפתח הציבורי של הלקוח

ד. המפתח הפרטי של הלקוח

שאלה מספר 10:

איזו מבין הטענות הבאות נכונה בהקשר של חתימה דיגיטלית?

א. מחשבים את ה hash של המידע שרוצים לחתום עליו. מצפינים את ה hash עם המפתח הפרטי של השולח, ושולחים את הhash המוצפן והמידע עצמו. האימות מתבצע על ידי המקבל ע"י פענוח ה hash המוצפן בעזרת המפתח הפומבי של החותם והשוואתו לתוצאת ביצוע hash על המידע שנשלח.

ב. מחשבים את ה hash של המידע שרוצים לחתום עליו. מצפינים את ה hash עם המפתח הפרטי של השולח, ושולחים את הhash המוצפן והמידע עצמו. האימות מתבצע על ידי המקבל ע"י פענוח ה hash המוצפן בעזרת המפתח הפרטי של החותם והשוואתו לתוצאת ביצוע hash על המידע שנשלח.

ג. מחשבים את ה hash של המידע שרוצים לחתום עליו. מצפינים את ה hash עם המפתח הפומבי של השולח, ושולחים את הhash המוצפן והמידע עצמו. האימות מתבצע על ידי המקבל ע"י ביצוע hash על ה hash המוצפן שהתקבל והשוואתו למידע שנשלח.

ד. מחשבים את ה hash של המידע שרוצים לחתום עליו. מצפינים את ה hash עם המפתח הפומבי של השולח, ושולחים את הhash המוצפן והמידע עצמו. האימות מתבצע על ידי המקבל ע"י פענוח ה hash המוצפן בעזרת המפתח הפרטי של החותם והשוואתו לתוצאת ביצוע hash על המידע שנשלח.

שאלה מספר 11:

מהי התקפת blind sql injection?

א. התוקף אינו מקבל את הפלט המקורי של הרצת השאילתא מהשרת, ולכן בונה את השאילתא באופן כזה שבדרך "עקיפה" יבין האם התשובה לשאילתא היא נכונה או לא. (מנגנון של True/false)

ב. התוקף מבצע ניסוי וטעיה של התקפות שונות מפני שאינו יכול (blind) לבצע התקפות מסוג sql injection. ההתקפות הללו שייכות למשפחות התקפות אחרות, למשל XSS ו CSRF

ג. התוקף גורם לקורבנות להזין פרמטרים לשאילתת sql, כך שהקורבנות לא מודעים לכך, כלומר, עיוורים.

ד. התוקף משתמש בדפדפנים של הקורבנות לביצוע התקפתה מסוג sql injection, כך שהשרת לא יודע מי התוקף, כלומר, עיוור.

<u>שאלה מספר 12:</u>

עבור 23 ו g=3, אליס ובוב הריצו את פרוטוקול Diffie-Hellman. במהלך הרצת הפרוטוקול, אליס שלחה לבוב את המספר 12 ובוב שלח לה את המספר 13. מה מהבאים יכול להיות המספר הסודי שנבחר?

א. 18

ב. 15

ג. 16

ד. 17

--- סוף המבחן ---